

MITRE ATT&CK Framework

The MITRE ATT&CK Framework is a globally used cybersecurity knowledge base that helps security professionals understand attacker behavior. ATT&CK stands for Adversarial Tactics, Techniques, and Common Knowledge. The framework is used by SOC analysts, threat hunters, penetration testers, and incident response teams to study how attackers operate during cyberattacks.

The Enterprise ATT&CK Matrix contains 14 tactics that represent different stages of an attacker's campaign. Each tactic contains multiple techniques that attackers use to achieve their objectives. By understanding these tactics and techniques, organizations can improve detection, monitoring, and response capabilities.

TACTICS AND THERE TECHNIQUES

1. Reconnaissance (TA0043)

What the Tactic Represents

Reconnaissance is the first stage of the cyber attack lifecycle where attackers gather information about their target before launching an attack. They collect details such as employee information, company domains, IP addresses, technologies used, and publicly accessible services. The information gathered during this stage helps attackers plan a more targeted and successful attack.

Techniques

T1595 – Active Scanning

Active Scanning is the process of probing a target's systems or network to identify open ports, running services, software versions, and potential vulnerabilities. Attackers use scanning tools such as Nmap to understand the target environment before attempting exploitation.

T1589 – Gather Victim Identity Information

In this technique, attackers collect information about employees, including names, email addresses, phone numbers, job roles, and organizational structure. This information is often gathered from company websites and social media platforms and is later used in phishing or social engineering attacks.

T1598 – Phishing for Information

Attackers send fake emails or messages that appear to come from trusted sources to trick users into revealing sensitive information. Instead of installing malware, the goal is to collect credentials, confidential documents, or other valuable information that can be used in later stages of the attack.

Threat Actor

APT29 (Cozy Bear) is known for conducting extensive reconnaissance before launching attacks. The group carefully gathers information about government agencies and organizations to create highly convincing spear-phishing campaigns.

SOC Detection Method

SOC analysts monitor for repeated scanning attempts from external IP addresses, unusual DNS queries, and large volumes of requests targeting public-facing systems. Network intrusion detection systems (IDS) and firewall logs can help identify reconnaissance activities before attackers gain access.

2. Resource Development (TA0042)

What the Tactic Represents

Resource Development is the stage where attackers prepare the resources needed to conduct an attack. Instead of interacting with the victim directly, they build or acquire the infrastructure, malware, domains, and tools required for future operations.

Techniques

T1583 – Acquire Infrastructure

Attackers purchase or rent servers, virtual private servers (VPS), cloud services, or domain names that will later be used to host phishing websites, malware, or command-and-control servers. This infrastructure helps hide the attacker's real identity.

T1587 – Develop Capabilities

In this technique, attackers create or modify malware, exploits, phishing kits, or other malicious tools. They often customize these tools to bypass security software and increase the success rate of their attacks.

T1608 – Stage Capabilities

Attackers upload malware, phishing documents, or other payloads to websites or cloud storage so they are ready to be delivered to victims during the attack. Staging resources in advance makes the attack more efficient.

Threat Actor

APT41 is known for developing sophisticated malware and maintaining large attack infrastructures. The group frequently creates customized tools that support both espionage and financially motivated attacks.

SOC Detection Method

Security teams monitor newly registered domains, suspicious hosting providers, and threat intelligence feeds that identify malicious infrastructure. Detecting communication with known malicious domains can help stop attacks before they progress.

3. Initial Access (TA0001)

What the Tactic Represents

Initial Access is the stage where attackers successfully enter the victim's environment. They may exploit software vulnerabilities, use stolen credentials, or trick users into opening malicious files. Once initial access is achieved, attackers begin establishing control over the compromised system.

Techniques

T1566 – Phishing

Phishing is one of the most common techniques used to gain initial access. Attackers send fraudulent emails containing malicious attachments or links that trick users into opening malware or entering their login credentials on fake websites.

T1190 – Exploit Public-Facing Application

Attackers exploit security vulnerabilities in internet-facing applications such as websites, web servers, VPN gateways, or web applications. A successful exploit allows attackers to access the internal network without requiring valid user credentials.

T1133 – External Remote Services

Attackers use stolen usernames and passwords to log into remote access services such as VPN, SSH, or Remote Desktop Protocol (RDP). Since valid accounts are used, these attacks can appear similar to normal user activity.

Threat Actor

FIN7 frequently uses phishing campaigns to gain initial access into corporate environments. The group often targets retail, hospitality, and financial organizations by sending carefully crafted phishing emails to employees.

SOC Detection Method

SOC analysts monitor email gateways for suspicious attachments and malicious links. They also analyze VPN, SSH, and RDP login activity to detect unusual login times, unknown locations, or repeated failed authentication attempts.

4. Execution (TA0002)

What the Tactic Represents

Execution is the stage where attackers run malicious code on the compromised system. This allows malware to start operating, execute commands, download additional payloads, or perform actions that support the attacker's objectives.

Techniques

T1059 – Command and Scripting Interpreter

Attackers use command-line interpreters such as PowerShell, Bash, or Command Prompt to execute malicious commands. These scripting tools allow attackers to automate tasks, download malware, and interact with compromised systems.

T1204 – User Execution

This technique relies on users performing an action, such as opening a malicious attachment or running an infected application. Social engineering is often used to convince users that the file is legitimate.

T1047 – Windows Management Instrumentation (WMI)

Windows Management Instrumentation (WMI) is a legitimate Windows administration tool that attackers abuse to execute commands remotely. Since WMI is commonly used by system

administrators, malicious activity may blend in with normal administrative operations.

Threat Actor

Lazarus Group frequently uses PowerShell scripts and Windows administration tools to execute malware after gaining access to victim systems. Their attacks often combine legitimate system utilities with custom malware to avoid detection.

SOC Detection Method

Security teams monitor PowerShell logs, command-line activity, WMI execution, and unusual process creation events. Endpoint Detection and Response (EDR) tools help identify suspicious execution patterns and alert analysts to possible malicious activity.

5. Persistence (TA0003)

What the Tactic Represents

Persistence is the stage where attackers ensure they can continue accessing a compromised system even after it is restarted or the user logs out. They create mechanisms that automatically execute malicious code whenever the system starts or a user logs in. This helps attackers maintain long-term access without repeatedly exploiting the system.

Techniques

T1547 – Boot or Logon Autostart Execution

Attackers modify startup folders, registry run keys, or startup services so that their malware automatically executes whenever the operating system boots or a user logs in. This ensures that the malicious software remains active even after a reboot.

T1136 – Create Account

Attackers create new local or domain user accounts with administrative privileges. These hidden or unauthorized accounts provide an alternative way to access the system if the original compromised account is detected or disabled.

T1053 – Scheduled Task/Job

Attackers use the operating system's task scheduler or cron jobs to automatically execute malicious programs at specific times or events. Scheduled tasks help maintain persistence while appearing similar to legitimate system maintenance tasks.

Threat Actor

APT29 frequently uses scheduled tasks and registry modifications to maintain persistence during long-term espionage campaigns. Their goal is to remain inside victim networks for extended periods without attracting attention.

SOC Detection Method

SOC analysts monitor the creation of new scheduled tasks, unauthorized registry modifications, startup folder changes, and unexpected user account creation. Endpoint Detection and Response (EDR) tools can alert analysts whenever persistence mechanisms are installed.

6. Privilege Escalation (TA0004)

What the Tactic Represents

Privilege Escalation occurs when attackers attempt to gain higher permissions after initially compromising a system. By obtaining administrator or root privileges, attackers can access sensitive information, disable security controls, and move more freely within the environment.

Techniques

T1068 – Exploitation for Privilege Escalation

Attackers exploit vulnerabilities in the operating system or installed software to gain administrator or root privileges. These vulnerabilities allow them to perform actions that normal users are not authorized to perform.

T1548 – Abuse Elevation Control Mechanism

Attackers bypass security mechanisms such as Windows User Account Control (UAC) or Linux privilege controls to obtain elevated permissions. This allows malicious processes to execute with administrative rights.

T1134 – Access Token Manipulation

Attackers steal or manipulate security tokens associated with privileged users. By impersonating these users, attackers can perform administrative actions without knowing the user's password.

Threat Actor

FIN7 commonly performs privilege escalation after gaining initial access. The group exploits vulnerabilities and abuses Windows security features to obtain administrative privileges

before stealing sensitive data or deploying ransomware.

SOC Detection Method

SOC analysts monitor privilege escalation events, unexpected administrator logins, abnormal User Account Control bypasses, and processes requesting elevated permissions. Security logs and EDR alerts help identify unauthorized privilege changes.

7. Defense Evasion (TA0005)

What the Tactic Represents

Defense Evasion involves techniques used by attackers to avoid detection by antivirus software, Endpoint Detection and Response (EDR) tools, firewalls, and security analysts. The objective is to remain hidden while continuing malicious activities inside the victim's environment.

Techniques

T1027 – Obfuscated Files or Information

Attackers encrypt, compress, or encode malware to hide its true content from antivirus software and security tools. Obfuscation makes malicious files more difficult to analyze and detect using signature-based detection methods.

T1070 – Indicator Removal on Host

Attackers delete event logs, temporary files, command history, and other forensic evidence to hide their activities. Removing these indicators makes incident investigations more difficult and delays detection.

T1218 – Signed Binary Proxy Execution

Attackers abuse trusted Windows utilities such as **regsvr32**, **rundll32**, or **mshta** to execute malicious code. Since these programs are legitimate Microsoft binaries, their activity often appears normal to security software.

Threat Actor

APT41 frequently uses obfuscated malware and trusted Windows utilities to bypass traditional security controls. Their campaigns often combine multiple defense evasion techniques to remain undetected for long periods.

SOC Detection Method

SOC analysts monitor unusual use of legitimate system binaries, unexpected log deletion, encoded PowerShell commands, and antivirus bypass attempts. Behavioral analysis helps detect suspicious activities that signature-based tools may miss.

8. Credential Access (TA0006)

What the Tactic Represents

Credential Access is the stage where attackers attempt to steal usernames, passwords, authentication tokens, or password hashes. Stolen credentials allow attackers to move laterally, access sensitive systems, and maintain persistence within the network.

Techniques

T1003 – OS Credential Dumping

Attackers extract usernames and password hashes from operating system memory, particularly from the Local Security Authority Subsystem Service (LSASS) process in Windows. These credentials can later be cracked or reused for unauthorized access.

T1110 – Brute Force

Attackers repeatedly attempt different username and password combinations until they successfully authenticate. Brute-force attacks may target VPN services, SSH servers, Remote Desktop, or web applications with weak passwords.

T1555 – Credentials from Password Stores

Attackers extract saved usernames and passwords from browsers, password managers, and other credential storage locations. These stored credentials often provide access to additional systems and online accounts.

Threat Actor

Lazarus Group has repeatedly used credential dumping and password theft techniques during espionage and financially motivated cyber campaigns. Stolen credentials help the group expand access throughout compromised networks.

SOC Detection Method

SOC analysts monitor for repeated failed login attempts, abnormal authentication patterns, suspicious access to the LSASS process, and execution of known credential dumping tools. EDR solutions can detect processes attempting to access sensitive credential storage.

9. Discovery (TA0007)

What the Tactic Represents

Discovery is the stage where attackers explore the compromised environment to understand its structure and identify valuable targets. They gather information about the operating system, users, network configuration, security software, and connected devices. This information helps attackers decide their next steps, such as privilege escalation or lateral movement.

Techniques

T1082 – System Information Discovery

Attackers collect information about the compromised system, including the operating system version, hostname, hardware details, installed software, and system configuration. This information helps them determine which exploits or tools are most suitable for the target environment.

T1016 – System Network Configuration Discovery

Attackers examine the network configuration by identifying IP addresses, DNS settings, gateways, and network interfaces. Understanding the network layout helps them locate other systems and identify potential paths for movement within the organization.

T1046 – Network Service Discovery

Attackers scan systems to identify active services such as SSH, HTTP, SMB, RDP, and FTP. Knowing which services are available helps them find vulnerable systems and opportunities for lateral movement.

Threat Actor

APT29 performs extensive discovery after gaining access to a network. The group carefully maps the victim's environment before moving to critical servers, allowing them to remain hidden while achieving their objectives.

SOC Detection Method

SOC analysts monitor for unusual execution of system discovery commands, internal network scanning, and repeated service enumeration. Security Information and Event Management (SIEM) solutions can correlate these activities to identify reconnaissance occurring inside the network.

10. Lateral Movement (TA0008)

What the Tactic Represents

Lateral Movement is the stage where attackers spread from one compromised system to other systems within the same network. Their goal is to reach high-value servers, domain controllers, or databases while expanding their control over the environment.

Techniques

T1021 – Remote Services

Attackers use legitimate remote administration services such as Remote Desktop Protocol (RDP), Secure Shell (SSH), Windows Remote Management (WinRM), or SMB to move between systems. Stolen credentials are commonly used to authenticate to these services.

T1550 – Use Alternate Authentication Material

Instead of passwords, attackers use stolen authentication tokens, Kerberos tickets, or NTLM password hashes to access other systems. This technique reduces the need to know the victim's actual password and can bypass some authentication controls.

T1570 – Lateral Tool Transfer

Attackers copy malware, scripts, or administrative tools from one compromised machine to another. These transferred tools help execute additional attacks without requiring internet downloads that might trigger security alerts.

Threat Actor

FIN7 frequently performs lateral movement after obtaining administrator privileges. The group uses stolen credentials and remote administration tools to compromise multiple systems before deploying ransomware or stealing financial information.

SOC Detection Method

SOC analysts monitor unusual remote logins, unexpected RDP or SSH sessions, file transfers between internal systems, and authentication attempts from uncommon hosts. EDR solutions and SIEM platforms can identify abnormal lateral movement patterns.

11. Collection (TA0009)

What the Tactic Represents

Collection is the stage where attackers gather valuable information from compromised systems before transferring it outside the organization. The collected data may include confidential documents, emails, databases, passwords, screenshots, or financial records.

Techniques

T1005 – Data from Local System

Attackers search local drives for important files such as documents, spreadsheets, databases, and configuration files. The collected information is usually stored temporarily before being exfiltrated from the network.

T1114 – Email Collection

Attackers access email accounts or mail servers to collect sensitive communications, attachments, contact lists, and business information. Email data often contains confidential information that can be used for espionage or financial gain.

T1119 – Automated Collection

Attackers use scripts or malware to automatically search for and gather specific types of files across multiple systems. Automation allows them to collect large amounts of valuable data quickly while reducing manual effort.

Threat Actor

APT41 is known for collecting intellectual property, confidential business documents, and sensitive organizational data during long-term espionage campaigns. The group often automates data collection to increase efficiency before exfiltration.

SOC Detection Method

SOC analysts monitor unusual file access, large numbers of file reads, abnormal email access, and automated scripts accessing sensitive directories. Data Loss Prevention (DLP) solutions and EDR tools help detect suspicious collection activities before data leaves the network.

12. Command and Control (TA0011)

What the Tactic Represents

Command and Control (C2) is the stage where attackers establish communication between the compromised system and their own remote server. This communication allows them to

send commands, receive stolen data, download additional malware, and control the infected system without being physically present. Attackers often try to hide this communication within normal network traffic to avoid detection.

Techniques

T1071 – Application Layer Protocol

Attackers use common protocols such as HTTP, HTTPS, DNS, or SMTP for communication with their command-and-control servers. Since these protocols are used in everyday network activity, malicious traffic can blend in with legitimate traffic and become difficult to detect.

T1090 – Proxy

Attackers route their communication through one or more proxy servers before reaching the victim. Using proxies hides the real location of the attacker and makes it more difficult for investigators to trace the source of the attack.

T1573 – Encrypted Channel

Attackers encrypt command-and-control traffic using protocols such as TLS or SSL. Encryption prevents defenders from easily inspecting the contents of the communication and helps attackers avoid network monitoring tools.

Threat Actor

Lazarus Group commonly establishes encrypted command-and-control channels after compromising victim systems. The group frequently disguises malicious traffic as normal HTTPS communication to maintain long-term access.

SOC Detection Method

SOC analysts monitor for unusual outbound network connections, periodic beaconing behavior, encrypted communication with unknown domains, and connections to malicious IP addresses. Network Detection and Response (NDR) and SIEM solutions help identify suspicious command-and-control traffic.

13. Exfiltration (TA0010)

What the Tactic Represents

Exfiltration is the stage where attackers transfer stolen information from the victim's environment to an external location under their control. The stolen data may include confidential documents, financial information, customer records, intellectual property, or

login credentials. Attackers usually attempt to hide this activity by using encrypted channels or trusted cloud services.

Techniques

T1041 – Exfiltration Over C2 Channel

Attackers send stolen information through the same command-and-control channel that is already established with the compromised system. Using the existing communication channel reduces the chance of generating additional suspicious network traffic.

T1020 – Automated Exfiltration

Attackers use malware or automated scripts to continuously collect and transfer sensitive data without requiring manual intervention. This technique enables the theft of large amounts of information over an extended period.

T1567 – Exfiltration to Cloud Storage

Attackers upload stolen files to cloud storage services such as Dropbox, Google Drive, or OneDrive. Since these services are widely used by organizations, malicious uploads may appear similar to normal business activity.

Threat Actor

APT29 has been observed exfiltrating sensitive government and organizational data using encrypted channels and trusted cloud-based services. Their objective is to steal information while remaining undetected for as long as possible.

SOC Detection Method

SOC analysts monitor large outbound data transfers, unusual uploads to cloud storage platforms, abnormal network traffic outside business hours, and unexpected data movement from sensitive servers. Data Loss Prevention (DLP) solutions help identify unauthorized data exfiltration.

14. Impact (TA0040)

What the Tactic Represents

Impact is the final stage of the attack where attackers disrupt normal business operations or damage systems and data. Depending on their objectives, attackers may encrypt files, delete backups, destroy data, or shut down critical services. This stage is commonly associated with ransomware attacks and destructive cyber operations.

Techniques

T1486 – Data Encrypted for Impact

Attackers encrypt files and demand a ransom payment in exchange for the decryption key. Victims lose access to important business data until backups are restored or the ransom is paid.

T1490 – Inhibit System Recovery

Attackers delete backup files, restore points, or shadow copies to prevent organizations from recovering encrypted or deleted data. This increases the impact of ransomware attacks and makes recovery more difficult.

T1529 – System Shutdown/Reboot

Attackers intentionally force systems to shut down or restart unexpectedly. Repeated shutdowns disrupt business operations, reduce service availability, and may cause additional damage to systems.

Threat Actor

FIN7 has used ransomware to encrypt organizational data and disrupt business operations. The group often combines data theft with ransomware, threatening to publish stolen information if the ransom is not paid.

SOC Detection Method

SOC analysts monitor for mass file encryption, deletion of backup files, sudden shutdown commands, and unusual disk activity. EDR solutions can quickly detect ransomware behavior and isolate infected systems before the attack spreads.

APT GROUP PROFILES

1. APT29 (Cozy Bear)

Who They Are

APT29, also known as Cozy Bear, is a Russian state-sponsored cyber espionage group believed to operate on behalf of Russian intelligence services. The group is known for conducting stealthy and long-term cyber espionage campaigns against governments, research organizations, and critical infrastructure.

Industries Targeted

- Government
- Defense
- Healthcare
- Energy
- Technology
- Research organizations

Common Tactics and Techniques

Tactic	Technique
Initial Access	T1566 – Phishing
Persistence	T1053 – Scheduled Task
Credential Access	T1003 – OS Credential Dumping
Exfiltration	T1041 – Exfiltration Over C2 Channel

Known Campaign

APT29 was widely linked to the **SolarWinds supply chain attack** discovered in 2020. The attackers compromised software updates distributed by SolarWinds, allowing them to infiltrate thousands of organizations worldwide, including government agencies and private companies.

2. APT41

Who They Are

APT41 is a Chinese threat group known for carrying out both cyber espionage and financially motivated attacks. Unlike many other APT groups, APT41 targets organizations for intelligence gathering while also conducting cybercrime for financial gain.

Industries Targeted

- Healthcare
- Telecommunications
- Software
- Manufacturing
- Gaming

- Government

Common Tactics and Techniques

Tactic	Technique
Resource Development	T1587 – Develop Capabilities
Persistence	T1547 – Boot or Logon Autostart Execution
Defense Evasion	T1027 – Obfuscated Files or Information
Collection	T1119 – Automated Collection

Known Campaign

APT41 has been linked to several software supply chain compromises and attacks against healthcare and telecommunications organizations. The group frequently develops custom malware to bypass security controls and maintain long-term access to victim environments.

3. FIN7

Who They Are

FIN7 is a financially motivated cybercriminal group that has operated for many years, targeting organizations to steal payment card information and deploy ransomware. The group is highly organized and often uses sophisticated phishing campaigns to gain initial access.

Industries Targeted

- Retail
- Hospitality
- Financial Services
- Restaurants
- Manufacturing

Common Tactics and Techniques

Tactic	Technique
Initial Access	T1566 – Phishing
Lateral Movement	T1021 – Remote Services
Credential Access	T1110 – Brute Force
Impact	T1486 – Data Encrypted for Impact

Known Campaign

FIN7 has conducted multiple phishing campaigns targeting businesses worldwide. In recent years, the group has also been associated with ransomware operations, where stolen data is used to pressure victims into paying large ransom demands.